



Weekly Cyber Threat Intelligence Report

Reporting window: 18 - 25 August 2026

Australia - APAC - Global - Emerging Threats - IOCs to Add

Prepared for: Jordan

Classification: TLP:CLEAR - cleared for public release

Source: CyberSec Vault automated intel sweep

PUBLIC

Executive Summary

8 Critical CVE items	4 Other notable vulns	6 Actively exploited	7 Notable breaches	4 PoCs / tools	23 IOCs to add
-------------------------	--------------------------	-------------------------	-----------------------	-------------------	-------------------

Three threads ran through this window. First, **AI moved from talking point to tooling** on both sides of the fight: five US agencies warned of **AI-generated exploit scripts** probing Siemens S7 PLCs across water, energy and manufacturing; Cisco Talos documented **UAT-10147** using AI-generated playbooks alongside a BYOVD EDR kill and a Linux rootkit; Bitdefender's **SilkParasite** ran seven RAT families against Central Asian governments; and Wiz's autonomous **Red Agent** found, exploited and blast-radius-assessed a GitHub Actions injection in a Snowflake repo with no human involved - a bug introduced by a **Copilot Autofix PR** and missed by GitHub Advanced Security. Second, **AI infrastructure itself is now KEV-grade attack surface**: both CISA KEV additions this week were AI platforms (**MLflow** CVE-2026-64849, **Ray** CVE-2025-62593), joined by an uncatalogued **isolated-vm** sandbox escape with no CVE at all. Third, **the supply chain shifted from application code to build infrastructure**: a crates.io maintainer compromise put a payload in **arrayref**'s build script - compiling alone executes it - while 14 npm packages ran **RedC2 4.0** on import with no install hook, and Head Mare turned victims' own **TrueConf** servers into installer-distribution points. Elsewhere: GitLab, TrueConf and Zimbra were exploited within days of disclosure, Cisco shipped **five CVSS 10.0** flaws in one release, Check Point released a public PoC weaponising **Defender's own signed driver** (which cannot be blocklisted without breaking Defender), and breaches ran from CareCloud (3.76M patients) to Latvia's CSDD (two-thirds of the country, entire leadership resigned). **No Australia-specific items surfaced this window**. One correction of record: Microsoft **retracted** the exploited-in-the-wild status of Entra ID CVE-2026-69836.

AUSTRALIA - SPECIFIC

Local orgs & data

No Australia items identified this reporting window.

APAC - SPECIFIC

Regional incidents & actors

UAT-10147 (Chinese-speaking) - SPECTRE implant, BYOVD EDR kill, Linux rootkit, agentic AI in post-compromise ops

CRITICAL

VERIFIED

APT

China

AI

BYOVD

Cisco Talos (Joey Chen) profiled a Chinese-speaking actor hitting Windows IIS and Linux web servers across government, education, media, tech and gaming in Brazil, Bolivia, China, Canada and Vietnam. Initial access is mass exploitation of public vulnerabilities; post-compromise is where it matters - Talos documents **AI-generated operational playbooks, exploit automation and troubleshooting logic** alongside Metasploit, ysoserial, PentestGPT and DeepAudit. The SPECTRE implant is cross-platform C2 with process injection, credential theft, anti-analysis, **BYOVD kernel EDR bypass** (vulnerable MSI/Dell drivers), a **Linux kernel rootkit** and in-memory web shells; BadIIS provides SEO-fraud monetisation. Pull the full IOC appendices from both Talos posts.

PoC: Active exploitation in the wild (mass access via public vulns)

Refs: [blog.talosintelligence.com](#) · [blog.talosintelligence.com](#) · [thehackernews.com](#)

SilkParasite - China-nexus espionage vs Central Asian governments, 7 RAT families, AI-assisted

HIGH

VERIFIED

APT

China

Espionage

Bitdefender's near-year-long investigation - triggered by an infection at an economy-related government institution - maps a China-nexus operation (medium confidence) against ministries and agencies in Uzbekistan, Turkmenistan, Kyrgyzstan, Tajikistan, Georgia and Kazakhstan. Seven RAT families in one campaign, five previously undocumented: **DriveSilkRAT**, **CookiETagRAT**, **NomadRAT**, **GoginRAT**, **NodeEdgeRAT**, plus SpiceRAT (Talos-linked to SneakyChef). C2 abuses Google Drive; infrastructure traces to China Unicom backbone. Seven families in one operation means single-family signatures are a weak control - hunt on the Google Drive C2 pattern and shared loader behaviour.

Refs: [bitdefender.com](#) · [thehackernews.com](#) · [therecord.media](#)

Sakura Internet (Japan) - up to 1,360,563 accounts exposed at a national cloud/hosting provider

HIGH

VERIFIED

Breach

Japan

Hosting

Sakura Internet - significant Japanese national infrastructure, including in the government cloud space - disclosed a compromise of its sales/customer-management system affecting up to 1,360,563 accounts. It surfaced while investigating a separate, smaller Sakura Rental Server incident (583 accounts). No card data was stored in the affected system; some hashed passwords may be exposed and exfiltration is not yet confirmed. Hosting-provider account data is **control-plane data** - the downstream risk is access to customer infrastructure and social-engineered account recovery, making this a supply-chain event for every hosted customer.

Refs: bleepingcomputer.com · cybersecuritynews.com · teiss.co.uk

Dahua - 14,530 cameras compromised in a 35-day campaign (Operation CameraSwarm)

HIGH

VERIFIED

IoT

Botnet

P2P

Hunt.io tracked a 17 Jun - 22 Jul 2026 campaign compromising 14,530 Dahua devices: 12,324 via credential attacks, 1,923 via authentication bypass (CVE-2021-33044 / CVE-2021-33045 using the **p2pwn** tool, which installs a persistent **p2pwn / p2password** backdoor account) and 283 via P2P relay. Compromises concentrate in Russia and Ukraine. The P2P detail breaks standard exposure assessment: vendor P2P cloud-relay is on by default, so a NAT'd, non-port-forwarded camera is still reachable - scanning your own external ranges will not enumerate these devices.

PoC: **Active exploitation in the wild - 'p2pwn' tooling vs CVE-2021-33044/33045**

Refs: bleepingcomputer.com · thehackernews.com · hunt.io

First documented Android car head-unit malware - DoFun firmware updater, MoYu Group, BADBOX-linked proxy botnet

MEDIUM

VERIFIED

Android

Automotive

Botnet

Kaspersky documented the first Android car head-unit malware, spreading through **DoFun firmware's own built-in updater**: the legitimate system app **TWCore** pulls the **JarService** dropper, which loads C2 modules including **zhima** (eight variants found, earliest v57) - a reverse proxy turning head units into residential proxy-botnet nodes - plus click fraud. Attributed to **MoYu Group**, linked to **BADBOX**. Monetisation is ad fraud and proxy resale, not vehicle control. DoFun says the update-channel issue is fixed (vendor claim, unconfirmed). The transferable lesson: a trusted OEM update channel is a supply-chain path into a device class nobody inventories.

Refs: securelist.com · bleepingcomputer.com · kaspersky.com

GLOBAL - ACTIVELY EXPLOITED & CRITICAL CVEs

Patch now

CVE-2026-19478 - GitLab CE/EE GraphQL code injection (CVSS 9.4), exploited within days

CRITICAL

VERIFIED

DevOps

Unauth

Exploited

Code injection via a GraphQL directive lets a **remote, unauthenticated** attacker modify or delete public projects and user data - low complexity, no privileges, no user interaction. Affects 18.2 to <18.11.11, 19.0 to <19.0.8, 19.1 to <19.1.6 and 19.2 to <19.2.4; GitLab shipped an **out-of-band** release on 17 Aug and exploitation followed within days. The same patch fixes **CVE-2026-19650** (7.1), a GraphQL multiplex CSRF allowing mutations via GET. GitLab.com and Dedicated are already patched; this is a **self-managed** problem. Patch immediately and audit public-project and user-record deletions.

PoC: **Public - watchTowr reproduced within minutes of disclosure; active exploitation in the wild**

Refs: helpnetsecurity.com · horizon3.ai · docs.gitlab.com

CVE-2026-72529 / CVE-2026-72530 - TrueConf Server unauth RCE + sandbox escape (CISA KEV, Head Mare)

CRITICAL

VERIFIED

KEV

RCE

Exploited

CVE-2026-72529 (CVSS 9.8) is missing authentication: a remote attacker reaching TrueConf Server on **TCP 4307** (open by default) can invoke an undocumented function and run an arbitrary script with no credentials. CVE-2026-72530 is a sandbox escape to host. CISA added both to KEV and gave federal agencies a **three-day** deadline on 72529. Kaspersky attributes exploitation to **Head Mare** since at least July 2026, targeting Russian transport, energy, IT, electronics and software firms. Fixed in 5.3.9 / 5.4.9 / 5.5.5, released 18 June 2026 - the patch has been available for two months.

PoC: Active exploitation in the wild since at least July 2026 (Head Mare)

Refs: bleepingcomputer.com · cisa.gov · securityweek.com

CVE-2026-64849 - MLflow DNS-rebinding SSRF bypass to cloud credential theft (CISA KEV)

CRITICAL

VERIFIED

AI/LLM

KEV

SSRF

CVSS 9.3 SSRF via the **unauthenticated** POST `/api/2.0/mlflow/webhooks/{id}/test` endpoint, bypassing `_validate_webhook_url` through redirect and DNS-rebinding TOCTOU. The endpoint is **synchronous and returns the upstream status and body**, turning a blind SSRF into a fully readable one - straight to AWS IMDS. Observed in the wild stealing cloud credentials, dropping cryptominers and creating persistent IAM users. The default mlflow server ships with no authentication and MLflow sees 30M+ monthly downloads. Fixed in **3.15.0** (pins the validated peer IP at TCP connect). Patch, put the tracking server behind auth, and rotate any reachable cloud credentials.

PoC: Active exploitation in the wild - IMDS credential theft, cryptominers, persistent IAM users

Refs: bleepingcomputer.com · thehackernews.com · securityaffairs.com

CVE-2025-62593 - Ray dashboard code injection via User-Agent bypass + DNS rebinding (CISA KEV)

CRITICAL

VERIFIED

AI/LLM

KEV

RCE

CVSS 9.4 code injection in Ray's dashboard/API. The guard that required a Mozilla User-Agent prefix is bypassable, and combined with DNS rebinding the attack becomes **browser-driven RCE** - a victim merely visiting a malicious page (malvertising is a live vector) exposes an internal Ray cluster. CISA added it to KEV on 17 Aug under BOD 26-04 with a three-day FCEB deadline, and the **RondoDox** DDoS botnet incorporated it within days. Fixed in Ray **2.52.0**. Second AI-infrastructure KEV entry this week.

PoC: Active exploitation in the wild - weaponised by the RondoDox DDoS botnet within days

Refs: cisa.gov · thehackernews.com · securityaffairs.com

CVE-2026-19490 / CVE-2026-19489 - Citrix NetScaler ADC and Gateway authentication bypass (CVSS 9.3)

CRITICAL

VERIFIED

Appliance

AuthBypass

Edge

CVE-2026-19490 (9.3) is an authentication bypass on certain Gateway and AAA server configurations - **no credentials, no user interaction**; CVE-2026-19489 (8.8) is a memory overflow. Affected: ADC/Gateway 14.1 before 14.1-73.32, 13.1 before 13.1-63.21, ADC FIPS before 14.1-73.32 FIPS, FIPS/NDcPP before 13.1-37.277, and **SecurAccess ZTNA Hybrid** using customer-managed NetScaler. Citrix-managed cloud and Adaptive Authentication are already patched. NetScaler remains one of the most reliably weaponised edge appliances - patch on the assumption a working exploit appears quickly.

Refs: thehackernews.com · bleepingcomputer.com · csoonline.com

Cisco Crosswork and Secure Workload - nine flaws patched, five at CVSS 10.0

CRITICAL

VERIFIED

Network

Unauth

Enterprise

Nine CVEs, **five at CVSS 10.0**: CVE-2026-20030 (SQL injection, Crosswork, affects <=7.2.1, fixed 7.2.1-SP), CVE-2026-20357 (missing authentication), CVE-2026-20358 (external control of file-system path), CVE-2026-20359 (insufficiently protected credentials) and CVE-2026-20315 (improper access control in Secure Workload). Five maximum-severity flaws in one release points at a systemic unauthenticated API surface rather than five independent mistakes - and Crosswork holds credentials for, and can push configuration to, the network fabric. Found in Cisco's own internal testing; **no known exploitation, no workarounds**. Advisories published 19 Aug.

Refs: thehackernews.com · securityweek.com · sec.cloudapps.cisco.com

CVE-2026-32475 - Elementor Pro unauthenticated file upload to RCE (WordPress)

CRITICAL

VERIFIED

WordPress

FileUpload

RCE

CVSS 9.0. Elementor Pro's File Upload module runs **separate loops for validation and for processing**, and the two disagree on empty filename entries (UPLOAD_ERR_NO_FILE). A shaped multipart upload whose first entry has a blank filename makes the validator early-exit or mis-index while the processing loop still moves the attacker's file into wp-content/uploads/elementor/forms/. Filenames use a time-based uniqid(), so the landing path is brute-forceable. Requires a published form with a File Upload field. Patchstack disclosed 16 Jul; fixed in **4.2.2** (19-20 Aug). No known in-the-wild exploitation yet - which is exactly the window to patch in.

Refs: patchstack.com · thehackernews.com · bleepingcomputer.com

CVE-2026-69836 - Entra ID deserialization RCE (CVSS 10.0): Microsoft reversed the 'exploited' flag

CRITICAL

VERIFIED

Identity

Cloud

Correction

A CVSS 10.0 unauthenticated deserialization RCE (CWE-502) in the identity plane of a hyperscale cloud - Entra ID is the trust root for token issuance across M365, Azure and every federated SaaS app behind it. Microsoft says it is **fully mitigated service-side with no customer action required**, and on **21 August changed the 'Exploited' field from Yes to No with no explanation**. Carried here as a **correction of record**: the original 'exploited in the wild' reporting reached this vault through three separate intake paths that all traced to one upstream Microsoft bulletin. **Source count is not source independence** - a lesson worth more than the CVE itself.

PoC: Exploitation status RETRACTED by Microsoft on 21 Aug - no public PoC

Refs: cybersecuritydive.com · helpnetsecurity.com · socradar.io

CVE-2026-73570 - Zimbra SNMP command injection reached over SMTP, actively exploited

HIGH

VERIFIED

Mail

CmdInjection

Exploited

CVSS 8.9. Improper sanitisation during **SNMP notification processing** lets an unauthenticated attacker send crafted **SMTP** requests that end in arbitrary OS command execution as the zimbra user - a cross-protocol handoff that defeats scoping done on either protocol alone. Requires the optional zimbra-snmp package installed with notifications enabled (swat chdog is on by default). Affects ZCS <10.1.20. CERT Polska flagged active exploitation on 17 Aug; Shadowserver counted 270+ compromised instances. Hunt /var/log/zimbra.log restarts and new files in /opt/zimbra/jetty*/webapps/ and /tmp/ over the last 30 days.

PoC: Active exploitation in the wild - CERT Polska; Shadowserver found 270+ compromised instances

Refs: thehackernews.com · securityaffairs.com · socradar.io

GLOBAL - OTHER NOTABLE VULNERABILITIES

High severity & research

isolated-vm GHSA-864f-rcv7-6rh4 - V8 sandbox escape to host RCE, no CVE assigned

HIGH

VERIFIED

npm

SandboxEscape

AI

Type confusion in ExternalCopy's transferList handling (the array is double-walked; a TOCTOU accessor re-read through Get()) lets guest JavaScript corrupt host memory and hijack control flow - a **full sandbox escape**. isolated-vm exists for exactly one purpose: running code you do not trust, so there is no partial-trust deployment. Affects **all versions <=7.0.0**, fixed in **6.2.0 and 7.0.1** (8 Aug); ~1M npm downloads/week, used by n8n, Activepieces and Mastra AI. **No CVE was assigned** - CVE-keyed scanners will not flag it. Discovered by Endor Labs; no known in-the-wild exploitation.

Refs: github.com · endorlabs.com · thehackernews.com

'CDN Tsunami' - HTTP/3 to HTTP/1.1 translation abused for up to 350x DoS amplification against origins

MEDIUM

VERIFIED

DoS

CDN

Research

Two techniques - **HBA** (HTTP/3 Bandwidth Amplification, via QPACK header expansion) and **HCA** (HTTP/3 Connection Amplification) - abuse how CDNs translate client-facing HTTP/3 into HTTP/1.1 requests to the origin they front. A cheap request stream is amplified up to **350x against the customer's own origin**, and the victim site cannot configure its way out. All six evaluated providers (Alibaba, Baidu, Cloudflare, CloudFront, Fastly, Tencent) are susceptible to HBA; five of six to HCA - **Cloudflare is immune to HCA because it buffers the full request before opening the origin connection**. Academic disclosure (arXiv), no CVEs, no in-the-wild exploitation reported.

Refs: arxiv.org · thehackernews.com · guardianmssp.com

'Zombie Card' - rewriting NFC expiry revives expired Visa contactless cards (USENIX Security 2026)

MEDIUM

VERIFIED

Payments

NFC

Research

Anwar, DeCunha and Raza (UMass Amherst) revive expired Visa contactless cards for real in-store purchases by rewriting the expiry date the POS terminal reads over NFC - **without breaking any cryptography**. The cryptogram still validates because the expiry is not bound by the data the terminal independently verifies. Requires physical possession or sustained NFC proximity plus a two-phone relay (card emulator + POS emulator), the same PAN retained, and an issuer not re-checking expiry at authorisation. Disclosed to Visa May 2025, followed up Dec 2025. **Generalised lesson: a signature is only as useful as the set of fields it actually covers** - hunt for security-relevant fields adjacent to signed data.

Refs: usenix.org · theregister.com · thehackernews.com

CLAIM - wormable root RCE in Unitree G1 humanoid robot (tracking only)

WATCH

UNVERIFIED

Robotics

Unverified

Single social-media source, no CVE, no vendor advisory, no named researcher and no reviewed PoC. Web searching this window produced no independent corroboration. Logged for tracking only - **do not cite or action**. Retained because a wormable root RCE in a commercially deployed humanoid platform would be materially new, and it is worth having a marker in place if a credible advisory follows.

Refs: x.com/IntCyberDigest

GLOBAL - SOFTWARE SUPPLY CHAIN

Build-time execution

Rust crates.io - maintainer compromise backdoors arrayref, internment and append-only-vec via build script

CRITICAL

VERIFIED

Rust

BuildScript

DPRK-overlap

A compromised maintainer account published **arrayref 0.3.10**, **internment 0.8.7** and **append-only-vec 0.1.9** on 2026-08-20, each adding the typosquat dependency **proc-macro1** (of proc-macro2) whose `build.rs` reconstructs infrastructure from base64 fragments and drops an OS-matched payload for Linux, Windows x86-64 and macOS x86-64/ARM64. **Compiling alone executes it** - no call into the crate is needed. `arrayref` appears in over 35% of environments (~245M downloads) beneath `winit`, `egui`, `iced`, `blake3`, `Solana` and `Ethereum` tooling. Removed in 86-107 minutes; the attacker maliciously yanked good versions and the Rust SRT unyanked them. **No CVE, no patched version - pin to 0.3.9 or earlier**. `Wiz` reports request-path and TLS-issuer overlap with the DPRK Mastra and axios campaigns (overlap, not formal attribution).

PoC: Malicious releases live 86-107 minutes; no public PoC

Refs: blog.rust-lang.org · rustsec.org · wiz.io

npm - 14 trojanized calendar/streak packages drop RedC2 4.0 Linux backdoor on import

CRITICAL

VERIFIED

npm

Backdoor

AI

Fourteen functional calendar/streak utilities ship a bundled native binary that is **RedC2 4.0** (aka RedShell), an AI-assisted cross-platform implant with SOCKS5 proxying for internal pivoting. The mechanism is the point: **there is no install hook**, so hook-watching detection never fires. On module load the package locates the bundled binary, chmods it executable and detaches it - meaning **a single import anywhere in the dependency graph, including a transitive one, executes the payload**. You need not depend on it directly or call its API. Binaries masquerade as a 'native math accelerator' (math-core.bin, calc-cache.bin and similar); the loader is dist/index.mjs. Attribution: Trend Micro.

PoC: Sold on Hack Forums by 'MarlboroMan' since early June 2026

Refs: thehackernews.com · gbhackers.com · cyberpress.org

TrueConf - Head Mare trojanizes client installers server-side with PhantomCore / PhantomGraph

HIGH

VERIFIED

SupplyChain

Backdoor

Exploited

Head Mare exploits the unpatched TrueConf Server flaws above (KLCERT-26-057 / -058) to plant a web shell and **replace legitimate client installers with trojanized versions** - turning a victim's own on-prem conferencing server into a malware distribution point for every employee who downloads the client. PhantomCore lands as %LOCALAPPDATA%\TrueConf\Client\api-ms-win-crt-time-l1-1-0-2.dll; PhantomGraph uses a OneDrive account for C2. Note the scope: this is compromise of **customer-run TrueConf Server deployments**, not of TrueConf's own build pipeline. Patch to 5.3.9 / 5.4.9 / 5.5.5 and verify installer hashes served to clients.

PoC: Active exploitation in the wild since at least July 2026

Refs: securelist.com · ics-cert.kaspersky.com · bleepingcomputer.com

Wiz 'Red Agent' autonomously found and exploited a GitHub Actions injection in a Snowflake repo

HIGH

VERIFIED

CI/CD

AI

AgenticAI

An autonomous AI agent found a GitHub Actions **script injection** (crafted issue title interpolated into a run: block) in a public Snowflake repository, exploited it, validated access to Snowflake's internal Jira and assessed blast radius **with no human intervention, five days after the flaw went live**. Its first attempt failed on a comment-character escape and it self-corrected. The flaw was introduced 18 June via a PR co-authored by **GitHub Copilot Autofix** and **missed by GitHub Advanced Security**. Disclosed through HackerOne; Snowflake patched same day and rotated the Jira token on 24 June. The defensive read: AI writes the bug, AI misses the bug, AI finds and exploits the bug - and the attacker side of that loop is not exclusive to Wiz.

Refs: wiz.io · scworld.com · forbes.com

GLOBAL - PUBLIC PoCs & OFFENSIVE TOOL RELEASES

PoC / exploit code & tools

BTR_CLI - public PoC weaponising Microsoft Defender's own signed BTR.sys as a kernel primitive

CRITICAL

VERIFIED

PoC

Kernel

EDR-Bypass

Jiri Vinopal (Check Point Research) showed Defender's legitimately signed **BTR.sys** (Boot Time Removal, embedded in MpEngine.dll as the B00TTIMET00L resource) can be driven for **arbitrary kernel file and registry operations** - including deleting the security stack before it starts at boot. No flaw is exploited and no foreign driver is dropped, so the Vulnerable Driver Blocklist and WDAC do not apply: **BTR.sys cannot be blocklisted without breaking Defender**. The transaction protocol is undocumented and uses a hard-coded 256-byte RC4 key shared across all builds. BTR_CLI installs it as a service, bypassing SCM logging. Windows 7 through 11 25H2; requires prior admin. Live demo deleted the full Defender stack on 25H2 with Tamper Protection on. Black Hat USA 2026 / DEF CON 34, 20 Aug.

PoC: Public - PoC tool released with the Check Point research - github.com

Refs: research.checkpoint.com · thehackernews.com · csoonline.com

watchTowr reproduced GitLab CVE-2026-19478 within minutes of disclosure

HIGH

VERIFIED

PoC

Exploited

DevOps

Researchers reported reproducing the unauthenticated GraphQL code injection almost immediately after GitLab's out-of-band release, and Horizon3 published attack research on it. Exploitation in the wild followed within days. This is the compressed-timeline pattern in its purest form: an out-of-band patch is itself the disclosure signal, and the diff is the exploit spec. Treat any out-of-band release on an internet-facing devops platform as a same-day patch event.

PoC: Public reproduction reported; active exploitation followed within days

Refs: esecurityplanet.com · horizon3.ai · helpnetsecurity.com

p2pwn - in-the-wild exploit tool for Dahua auth bypass with persistent backdoor account

HIGH

VERIFIED

Tool

IoT

Exploited

Operation CameraSwarm used a tool tracked as **p2pwn** against five-year-old Dahua authentication bypasses, installing a persistent **p2pwn / p2password** account on 1,923 devices. Worth listing here because the account name is a directly huntable artefact and because it demonstrates that commodity tooling for legacy IoT CVEs is still producing five-figure compromise counts in 2026. Audit Dahua and OEM-rebadged devices for unexpected local accounts.

PoC: Observed in active use - CVE-2021-33044 / CVE-2021-33045 - hunt.io

Refs: hunt.io · bleepingcomputer.com · thehackernews.com

C2 hunting with Shodan and Censys - 827 live Cobalt Strike servers claimed

INFO

UNVERIFIED

Tool

Defense

CTI

A CTI walkthrough on fingerprinting live command-and-control infrastructure from internet-wide scan data, claiming 827 live Cobalt Strike servers identified. Defensive value is proactive blocking: every C2 server has to be reachable, so it has to be scannable. Single social-media source linking a third-party walkthrough - the technique is sound and well-established, but the 827 figure is uncorroborated. Retained as **unverified**.

Refs: x.com/aircorridor

GLOBAL - MALWARE & CAMPAIGNS**CISA / NSA / FBI / DOE / EPA - 'active threat' to Siemens S7 PLCs using AI-generated exploit scripts**

CRITICAL

VERIFIED

ICS/OT

AI

Advisory

Five US agencies issued a joint advisory on **AI-generated exploit scripts disguised as legitimate monitoring tools** targeting Siemens S7 series PLCs for reconnaissance and capability development, and explicitly assess the activity as **broader in scope than Siemens PLCs alone**. Sectors named: Critical Manufacturing, Energy, Water and Wastewater, Chemical, and Food and Agriculture. Targeting method is the whole access story - actors use **Censys and ZoomEye** to find internet-exposed PLCs running outdated software. NIST separately urged operators to change default passwords. Iran attribution appeared in press but is not settled. Actions: enumerate your own OT exposure in Censys/ZoomEye, remove internet-facing PLCs, change defaults.

PoC: Active reconnaissance and capability development against exposed PLCs

Refs: thehackernews.com · bleepingcomputer.com · cisa.gov

'Manic' Android - banking trojan and spyware hybrid with Wi-Fi/Bluetooth mesh relay exfiltration

HIGH

VERIFIED

Android

Banking

Spyware

ThreatFabric places Manic at the intersection of banking fraud and mobile surveillance, targeting **169 apps** across Ukrainian banks, government and identity services, Russian and European financial institutions, global fintech and crypto, and **military-focused communications**. Distribution is phishing sites and utility-impersonating droppers; infrastructure dates to February 2026. The novel capability is a **mesh relay over Wi-Fi or Bluetooth, up to four hops**, moving data through nearby infected devices that have connectivity. That defeats egress controls and network segmentation as containment: **an offline or air-gapped handset is not a contained handset** if an infected device is within radio range.

Refs: threatfabric.com · thehackernews.com · bleepingcomputer.com

Suspected Russian actors abuse Google OAuth consent and WhatsApp device linking (GTIG: UNC6293, UNC7005, UNC5976)

HIGH

VERIFIED

Phishing

OAuth

MFA-Bypass

Google Threat Intelligence Group tracked three clusters targeting academics, diplomats, defence personnel and think-tank researchers across Europe and the US: **UNC6293** (a sub-cluster of Ice Relic / APT29), **UNC7005** (which added fake voice-call and encrypted-chat pages post device-link to record audio and video) and **UNC5976** (fake file-sharing pages redirecting through the real Google OAuth flow). Both abused mechanisms are **legitimate features working as designed**: the victim satisfies MFA during a genuine flow, and the resulting token or linked device survives a password reset. **Password rotation and MFA enrolment do not remediate either**. Revoke OAuth grants and unlink devices first, then rotate credentials.

Refs: cloud.google.com · thehackernews.com · theregister.com

SynkLoader - Microsoft Teams phishing delivers a fake Windows lock screen for credential theft

HIGH

VERIFIED

Loader

Teams

Phishing

A previously unknown loader delivered via IT-helpdesk impersonation on Microsoft Teams, first compiled around 28 July 2026, using a 'PowerShell Cleaner' MSI lure hosted on Azure. Modules: **PhishLocker** (fake Windows 11 lock screen capturing credentials), **TrafficRedirector** (reverse proxy), an interactive shell/RAT and **StreamMaster** (VNC). The fake lock screen sidesteps the entire browser-phishing detection stack - no URL to inspect, no certificate, no lookalike domain; awareness training built on 'check the address bar' offers nothing. Detection detail worth circulating: it is a borderless full-screen app, so **Alt+Tab breaks the illusion**. Restrict external Teams messaging.

Refs: bleepingcomputer.com · cyberinsider.com · cybersecuritynews.com

FTP server banners as dead-drop resolvers - E4del and PINHOLE RATs

MEDIUM

VERIFIED

RAT

C2

DeadDrop

A ZIP-to-LNK chain active since early July 2026 delivers **E4del** (a Node.js/Electron RAT disguised as Discord, eight commands) and **PINHOLE** (14 commands, multi-stage). Two tradecraft details matter: the C2 address is read from an **FTP server banner pre-authentication with no file transfer**, so egress monitoring keyed on FTP data channels sees nothing; and PINHOLE pulls its C2 configuration from **Pinterest pins and SurveyMonkey surveys**, which are takedown-resistant and near-impossible to block wholesale. PINHOLE was still early-stage (11 execution events at analysis) - treat as emerging, not widespread. Alert on outbound TCP/21 from workstations.

Refs: socradar.io · bleepingcomputer.com · scworld.com

MacSync Stealer - 30+ rotating domains clustered by behavioural pivots, not static IOCs

MEDIUM

VERIFIED

macOS

Stealer

Methodology

Microsoft Defender Experts linked 30+ rotating domains to MacSync Stealer using recurring URI paths, macOS User-Agent strings, API-key headers and curl command-line options. The methodology is the deliverable, not the domain count - and Microsoft deliberately withheld the domain list. Rotating infrastructure exists to defeat blocklists: by the time a domain is published as an IOC it is retired. **Behavioural pivots survive rotation because an operator's tooling and habits change far more slowly than their domains**. Build detections on the request fingerprint, and treat any published domain list here as a short-lived bonus rather than the control.

Refs: microsoft.com · thehackernews.com · cybersecuritynews.com

Ransomware ecosystem - a parasitic layer forms atop the extortion economy

MEDIUM

VERIFIED

Ransomware

Ecosystem

Four signals about the ecosystem's internal dynamics rather than any single campaign: an affiliate **posing as a recovery firm to intercept its own gang's ransom payments**; 'Ransom Busters' charging victims up to \$60k on a claim of having hacked ransomware servers; an FBI/CISA/HHS **Medusa** advisory update on the RaaS affiliate model; and Black Kite finding **73% of ransomware hits land on mid-market** organisations. Leak-site hygiene note: the **LockBit claim against U.S. Bank resolved to a fourth-party incident** with no evidence its own systems were touched - and ShinyHunters' BOK Financial / Novocure listings plus the new **BlueWhale** group remain unverified leak-site claims. Treat leak-site listings as allegations until the named victim speaks.

Refs: bleepingcomputer.com · therecord.media · x.com/DailyDarkWeb

Iran-linked actors reportedly shut a UK power plant for four days (single-primary reporting)

HIGH

UNVERIFIED

ICS/OT

Iran

Unconfirmed

The Telegraph reported on 22 August that IRGC-linked actors caused a four-day shutdown at a UK power facility in July 2026 - described as the first such shutdown of a UK facility. **Every subsequent outlet cites the Telegraph**; SecurityWeek, CNBC, Times of Israel and others are write-ups, not independent confirmations, so this fails the three-independent-source bar. A UK government spokesperson downplayed it as a 'small-scale energy generator' with no risk to the wider grid. The facility is unnamed, no technical detail is public, and attribution is press-sourced only. Carried at **moderate confidence** - directionally consistent with the Siemens S7 advisory above, which is the corroborated OT story this week.

Refs: securityweek.com · cnbc.com · x.com/Telegraph

GLOBAL - NOTABLE BREACHES

CareCloud - 3,756,469 patients exposed in an EHR vendor breach

HIGH

VERIFIED

Healthcare

Vendor

PII

An intrusion into a CareCloud AWS environment between **10 and 16 March 2026** exposed 3,756,469 individuals. Disclosed to the SEC in March, but breach notifications only went out on **25 July** - a four-month notification lag. Exposed data includes **SSNs, passport numbers and banking details**, not just clinical PHI. EHR vendors concentrate risk: one vendor compromise exposes the patient population of every practice on the platform, which is how a single company reaches millions. Health records are not rotatable - the downstream extortion and medical-themed phishing exposure is permanent.

Refs: bleepingcomputer.com · therecord.media · hipaajournal.com

Latvia CSDD - 1.2M people and 200,000 businesses exposed; entire leadership resigns

HIGH

VERIFIED

Government

Breach

Accountability

The Road Traffic Safety Directorate (CSDD) breach exposed personal ID numbers, licence plates, payment records and addresses dating back to **2008** - 1.2 million individuals against a national population of ~1.8 million, so roughly two-thirds of the country, plus 200,000 businesses. The **entire CSDD leadership resigned** and a criminal investigation is under way amid claims of delayed disclosure. Executive accountability for a cyber incident remains rare enough that the resignations are the notable datapoint - a governance signal worth tracking alongside NIS2 and the broader regulatory direction.

Refs: therecord.media · eng.lsm.lv · dailysabah.com

9,300+ leaked AWS access keys from 2022-2026 are still active and valid

HIGH

VERIFIED

Cloud

Secrets

Remediation

Truffle Security found 64,024 unique key pairs across 431,875 exposures over four years; of the 10,616 pairs with complete credentials, **88% still authenticate**. Within that set: **768 corporate keys with full admin rights, 526 AWS root keys, and 242 IAM users holding AdministratorAccess**. The finding is not that keys leak - it is the four-year survival rate. Keys exposed in 2022 are live in 2026, which means detection never fired or was ignored, rotation was never forced, and AWS quarantine did not catch them. **Secret scanning is commodity; revocation is not**. Audit the gap between 'we scan for secrets' and 'the secret was actually revoked'.

Refs: bleepingcomputer.com · infosecurity-magazine.com · techzine.eu

ClarityCheck - 450GB bucket exposes ~9.04 million facial images, subjects are not customers

HIGH

VERIFIED

Biometric

Exposure

Privacy

Researcher Jeremiah Fowler found an unsecured, unencrypted S3 bucket with 'faces' and 'profiles' folders holding ~9.04 million images, reportedly including minors, exposed for months; a second misconfigured database exposed emails and phone numbers. Both are now secured. Two things make this a different category from a credential breach: **a face cannot be reissued**, so the standard rotate-reissue-monitor playbook does not exist; and **the subjects are not customers** - a reverse-lookup service aggregates images of people who never transacted with it, so there is no user base to notify. The index is already structured for identification, which is exactly what an attacker would otherwise have to build.

Refs: cybernews.com · malwarebytes.com · infotechlead.com

Pokemon Center (UK/DE) - customer data stolen in the CEVA Logistics third-party breach

MEDIUM

VERIFIED

ThirdParty

Retail

Logistics

Attackers breached **CEVA Logistics** - a CMA CGM subsidiary running 1,000 warehouses, 15M shipments and \$18.3B revenue - between roughly **29 July and 1 August 2026**, taking names, addresses, phone, email and order contents (no payment data or credentials). Pokemon Center's own systems were not touched; the exposed records are data it shared with CEVA to fulfil orders, and some pending orders were cancelled. The headline names the brand, but **CEVA is the breach** - the same incident also reached Valve, ING, bol, Ajax, De Bijenkorf and Ace & Tate. Delivery data is high-grade phishing fuel. Map which of your logistics providers hold customer PII.

Refs: bleepingcomputer.com · cybernews.com · forbes.com

SickKids (Toronto) - employee and job-applicant data exposed via a third-party software flaw

MEDIUM

VERIFIED

Healthcare

ThirdParty

HR

Identified 9 July 2026 via a flaw in third-party software supporting the careers site and HR/payroll functions. Affected population is workforce members employed **12 Dec 2016 - 31 Aug 2018**, plus SickKids Foundation and Boomerang Health staff; clinical systems and patient records were not affected. SickKids is a **repeat victim** (separate ransomware incident, Dec 2022). Two points worth generalising: **job-applicant data** is high-quality identity material held by an organisation the applicant may have no ongoing relationship with, and HR/recruitment platforms are routinely outside the scope of the security programme that covers clinical systems.

Refs: bleepingcomputer.com · therecord.media · theregister.com

Golf Canada - 568,972 accounts added to Have I Been Pwned (uncorroborated)

MEDIUM

UNVERIFIED

Breach

HIBP

Canada

HIBP loaded 568,972 unique email addresses obtained from Golf Canada around mid-2026, alongside names, dates of birth, gender and location; 76% were already in HIBP. Beyond the HIBP listing itself, only TechNadu has run original reporting - no major outlet has covered it independently, so it does not meet the three-source bar. **Golf Canada has not acknowledged the breach or notified affected users**, and the origin (misconfigured feature versus exploited vulnerability) is unconfirmed. Value is as credential-stuffing and phishing fuel; DOB plus location plus email is enough for convincing pretexting.

Refs: haveibeenpwned.com · technadu.com

INDICATORS OF COMPROMISE (IOCs) TO ADD

Blocklist / SIEM

Indicator	Type	Context	Reference
CVE-2026-19478	CVE	GitLab GraphQL unauth code injection (9.4); exploited - patch 19.2.4/19.1.6/19.0.8/18.11.11	helpnetsecurity.com
CVE-2026-72529 / CVE-2026-72530	CVE (KEV)	TrueConf Server unauth RCE on TCP 4307 + sandbox escape; Head Mare; fix 5.3.9/5.4.9/5.5.5	cisa.gov
CVE-2026-64849	CVE (KEV)	MLflow DNS-rebinding SSRF -> IMDS cred theft; fix 3.15.0	bleepingcomputer.com
CVE-2025-62593	CVE (KEV)	Ray dashboard RCE; RondoDox botnet; fix 2.52.0	cisa.gov

Indicator	Type	Context	Reference
CVE-2026-73570	CVE	Zimbra SNMP cmd injection via SMTP; exploited; fix ZCS 10.1.20	securityaffairs.com
CVE-2026-19490 / CVE-2026-19489	CVE	Citrix NetScaler auth bypass (9.3) + memory overflow; fix 14.1-73.32 / 13.1-63.21	bleepingcomputer.com
CVE-2026-32475	CVE	Elementor Pro unauth upload -> RCE; fix 4.2.2	patchstack.com
CVE-2026-20030 / -20315 / -20357 / -20358 / -20359	CVE	Cisco Crosswork + Secure Workload, five at CVSS 10.0; fix 7.2.1-SP	securityweek.com
GHSA-864f-rcv7-6rh4	Advisory (no CVE)	isolated-vm V8 sandbox escape, all <=7.0.0; fix 6.2.0 / 7.0.1	github.com
arrayref@0.3.10 / internment@0.8.7 / append-only-vec@0.1.9	Malicious crates	crates.io maintainer compromise 2026-08-20; pin arrayref <=0.3.9	rustsec.org
proc-macro1 (crate)	Malicious dependency	Typosquat of proc-macro2; build.rs drops OS-matched payload at compile time	blog.rust-lang.org
streak-metrics-math, kit-map-vim, streak-map-cache, map-streak-kit, streak-calc-math	Malicious npm packages	RedC2 4.0 Linux backdoor; executes on import, no install hook	thehackernews.com
math-core.bin, math-calc.bin, calc-cache.bin, calc-math.dat, calc-mapping.bin	File (bundled binary)	RedC2 payload posing as a 'native math accelerator'; loader dist/index.mjs	gbhackers.com
%LOCALAPPDATA%\TrueConf\Client\api-ms-win-crt-time-l1-1-0-2.dll	File (DLL)	PhantomCore dropped by Head Mare trojanized TrueConf installers	securelist.com
p2pwn / p2password (local account)	Account (backdoor)	Persistent account added to 1,923 Dahua cameras, Operation CameraSwarm	hunt.io
TWCore -> JarService -> zhima	Malware chain	Android car head-unit proxy botnet via DoFun firmware updater; MoYu / BADBOX	securelist.com
ultraspeed[.]pro	Domain	ClickFix lure served from compromised sites (single-source, 2026-08-20)	x.com/masaomi346
DriveSilkRAT, CookieTagRAT, NomadRAT, GoginRAT, NodeEdgeRAT, SpiceRAT	Malware families	SilkParasite China-nexus Central Asia campaign; Google Drive C2	bitdefender.com
E4del / PINHOLE	Malware families	C2 read from FTP banners pre-auth; PINHOLE config from Pinterest + SurveyMonkey	socradar.io
PhishLocker / TrafficRedirector / StreamMaster; 'PowerShell Cleaner' MSI	Malware modules / lure	SynkLoader via Teams phishing; fake Win11 lock screen; MSI hosted on Azure	bleepingcomputer.com
BTR.sys (BOOTTIMETOOL in MpEngine.dll) / BTR_CLI	LOLDriver / PoC tool	Defender's own signed driver as kernel primitive; cannot be blacklisted	github.com
wmic.exe on Windows 11 24H2 / 25H2	Detection artefact	WMIC fully removed (KB5120998) - its presence is now a high-fidelity IOC	support.microsoft.com
UNC6293 / UNC7005 / UNC5976	Threat clusters	Google OAuth consent + WhatsApp device-linking hijacks; revoke tokens before rotating	cloud.google.com

Defanged indicators - re-fang before importing. Verify against your environment before blocking.

TRENDS & EMERGING THREATS TO WATCH

Forward look

HIGH**Agentic AI is now routine tradecraft, not a capability claim**

Why it matters: Three independent, primary-source datapoints landed inside 72 hours: the CISA/NSA/FBI/DOE/EPA advisory on AI-generated exploit scripts against S7 PLCs, Talos on UAT-10147 using AI-generated playbooks and exploit automation in live intrusions, and Bitdefender on SilkParasite's AI-assisted malware. Wiz's Red Agent then closed the loop on the defensive side by finding and exploiting a real bug autonomously. This is no longer vendor forecasting - it is documented in incident reporting.

Watch for: recon and exploitation tooling that reads as machine-generated (uniform structure, monitoring-tool disguises); compressed dwell between disclosure and exploitation; scan traffic sourced from Censys/ZoomEye-derived target lists; AI-assisted PRs merged without adversarial review.

HIGH**AI/ML infrastructure has become KEV-grade attack surface**

Why it matters: Both CISA KEV additions this window were AI platforms - MLflow (CVE-2026-64849) and Ray (CVE-2025-62593) - and both default to no authentication with a readable SSRF or browser-driven RCE path straight to cloud credentials. isolated-vm added a sandbox escape with no CVE assigned, so CVE-keyed scanners miss it entirely. These systems sit inside the trust boundary, hold cloud credentials, and are typically owned by data teams rather than security.

Watch for: internet-exposed MLflow tracking servers, Ray dashboards, Langflow and LLM gateways; IMDS access from ML hosts; unexpected IAM user creation; cryptominers on GPU fleets; dependency advisories that ship without a CVE.

HIGH**Supply-chain payloads moved to build time and import time - install hooks are the wrong control**

Why it matters: arrayref's backdoor lived in the build script of an injected dependency, so merely compiling executes it. The 14 npm RedC2 packages carry no install hook at all and detonate on a single import anywhere in the graph, including transitively. Detection built around preinstall/postinstall hooks - the control most orgs actually deployed after 2024-2025 - does not fire on either. Neither has a patched version: the fix is a pin and a rebuild.

Watch for: build agents making outbound connections during compilation; new or renamed transitive dependencies (typosquats of proc-macro2 and similar); native binaries shipped inside JS packages; anything built or installed since 2026-08-20; developer and CI credentials that have not been rotated.

HIGH**Out-of-band patches are the disclosure event - exploitation is now measured in days**

Why it matters: GitLab shipped CVE-2026-19478 out of band on 17 Aug; researchers reproduced it almost immediately and in-the-wild exploitation followed within days. Zimbra CVE-2026-73570 already has 270+ compromised instances per Shadowserver. TrueConf's fix has been available since 18 June and CISA still had to set a three-day KEV deadline. An unscheduled release on an internet-facing platform is a same-day patch event, because the diff is the exploit specification.

Watch for: out-of-band advisories from GitLab, Citrix, Zimbra and similar; KEV additions with short deadlines; unpatched internet-facing devops, mail and conferencing servers; webshells and new admin accounts on anything that missed a same-week patch.

MED**Trusted, signed components are being repurposed instead of vulnerabilities exploited**

Why it matters: BTR.sys is Microsoft's own signed Defender driver - no flaw, no dropped driver, so the Vulnerable Driver Blocklist and WDAC have nothing to act on, and it cannot be blocklisted without breaking Defender. The same shape appears in Google OAuth consent and WhatsApp device linking (legitimate flows, MFA satisfied by the victim), Zombie Card (a field the signature does not cover), and DoFun's own firmware updater. Nothing here is a vulnerability in the CVE sense.

Watch for: service installs that bypass SCM logging; Defender component tampering pre-boot; OAuth grants and linked devices as a persistence class distinct from credentials; vendor update channels as a distribution path; security-relevant fields sitting outside what a signature actually binds.

MED

Third and fourth-party incidents are the dominant breach vector - and the named victim is rarely the breach

Why it matters: CEVA Logistics produced simultaneous exposures at Pokemon Center, Valve, ING, bol and others; CareCloud's compromise reaches the patient population of every practice on the platform; SickKids was breached through its careers/HR software; Sakura Internet's exposure is control-plane data for every hosted customer. Meanwhile the LockBit claim against U.S. Bank resolved to a fourth-party incident - the headline named an organisation that was not breached.

Watch for: logistics, EHR, HR/recruitment and hosting providers holding your customer or workforce PII; contract terms on breach notification timelines (CareCloud's was four months); leak-site listings treated as fact before the named victim responds; concentration risk where one vendor serves many of your business units.

PRIORITY ACTIONS THIS WEEK

Area	Action
Patch now	GitLab -> 19.2.4/19.1.6/19.0.8/18.11.11 (CVE-2026-19478); TrueConf -> 5.3.9/5.4.9/5.5.5 (CVE-2026-72529/72530, KEV); MLflow -> 3.15.0 (CVE-2026-64849, KEV); Ray -> 2.52.0 (CVE-2025-62593, KEV); Zimbra -> 10.1.20 (CVE-2026-73570); NetScaler -> 14.1-73.32 / 13.1-63.21 (CVE-2026-19490); Elementor Pro -> 4.2.2 (CVE-2026-32475); Cisco Crosswork -> 7.2.1-SP; isolated-vm -> 6.2.0 / 7.0.1.
Block IOCs	Import the 23 IOC-table rows into firewall/EDR/SIEM: CVE and KEV IDs for alerting, the malicious crate and npm package names, RedC2 binary filenames, the PhantomCore DLL path, the p2pwn/p2password account name, the TWCore/JarService/zhima chain, ultraspeed[.]pro, and the SilkParasite RAT family names. Alert on wmic.exe execution on Windows 11 24H2/25H2 - it should no longer exist.
Supply chain	Pin arrayref to <=0.3.9 and rebuild anything compiled since 2026-08-20; audit for the proc-macro1 typosquat and the 14 RedC2 npm packages; there are no patched versions for either. Move detection off install hooks onto build-time and import-time execution. Rotate developer, CI and cloud secrets reachable from affected build agents.
AI infrastructure	Inventory MLflow, Ray, Langflow and LLM gateways and get them off the internet and behind authentication; rotate any cloud credentials reachable from those hosts and check IMDS access logs. Add non-CVE advisories (GHSA/RUSTSEC) to the vulnerability feed - isolated-vm and arrayref have no CVE and will not appear otherwise.
Assume compromise	Treat internet-exposed GitLab, Zimbra and TrueConf servers that missed a same-week patch as potentially compromised: hunt webshells, /opt/zimbra/jetty*/webapps/ and /tmp/ additions, public-project deletions, and verify installer hashes served to TrueConf clients.
Identity	Revoke OAuth grants and unlink devices BEFORE rotating credentials - password resets do not remediate token or device-link persistence. Review external Microsoft Teams messaging policy given SynkLoader, and brief staff that a lock-screen prompt from a borderless app is defeated by Alt+Tab.
OT / ICS	Search Censys and ZoomEye for your own internet-exposed PLCs and remove them; change default credentials on S7 and equivalent controllers; extend the scope beyond Siemens per the joint advisory. Audit Dahua and OEM-rebadged cameras for unexpected local accounts and disable vendor P2P.
Third parties	Map which logistics, EHR, HR/recruitment and hosting providers hold your customer or workforce PII, and check contractual breach-notification timelines. Treat ransomware leak-site listings as allegations until the named victim confirms - one this week resolved to a fourth-party incident.